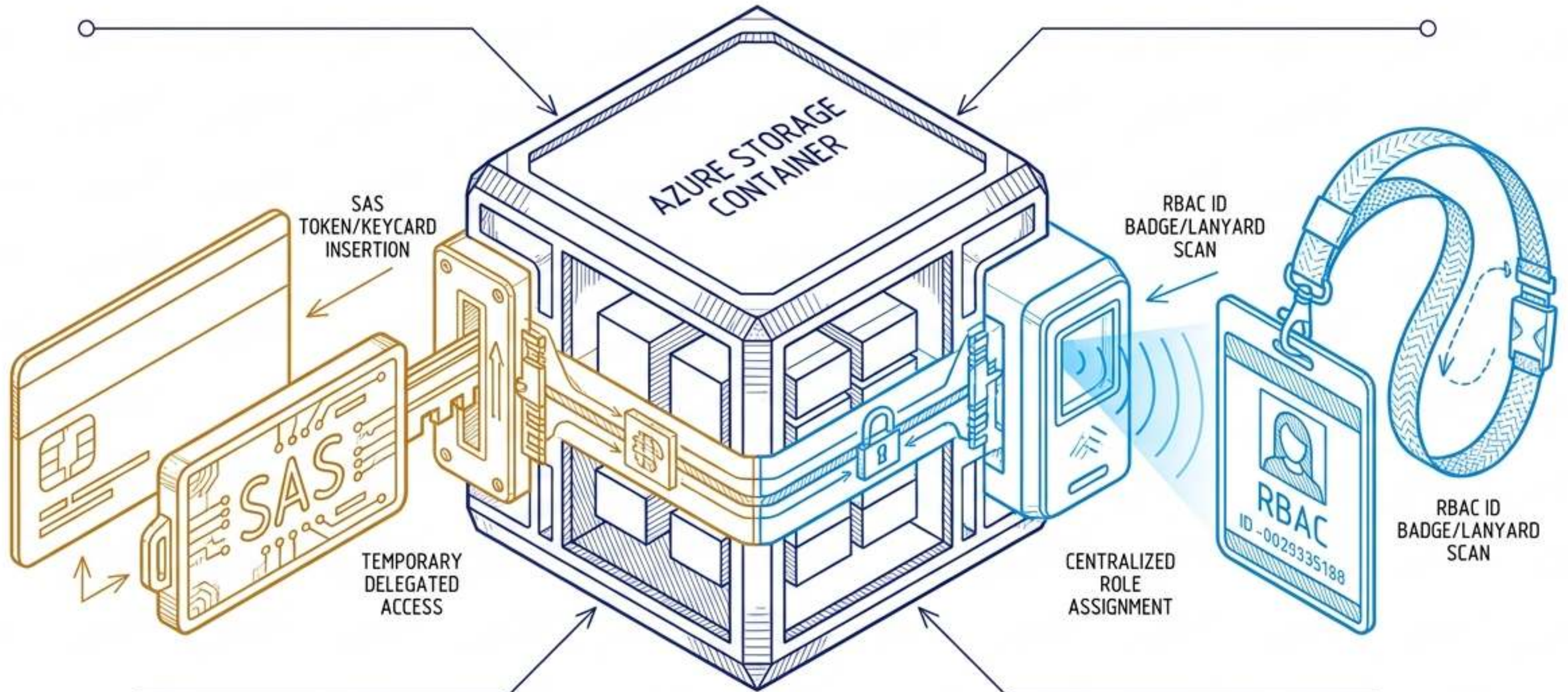




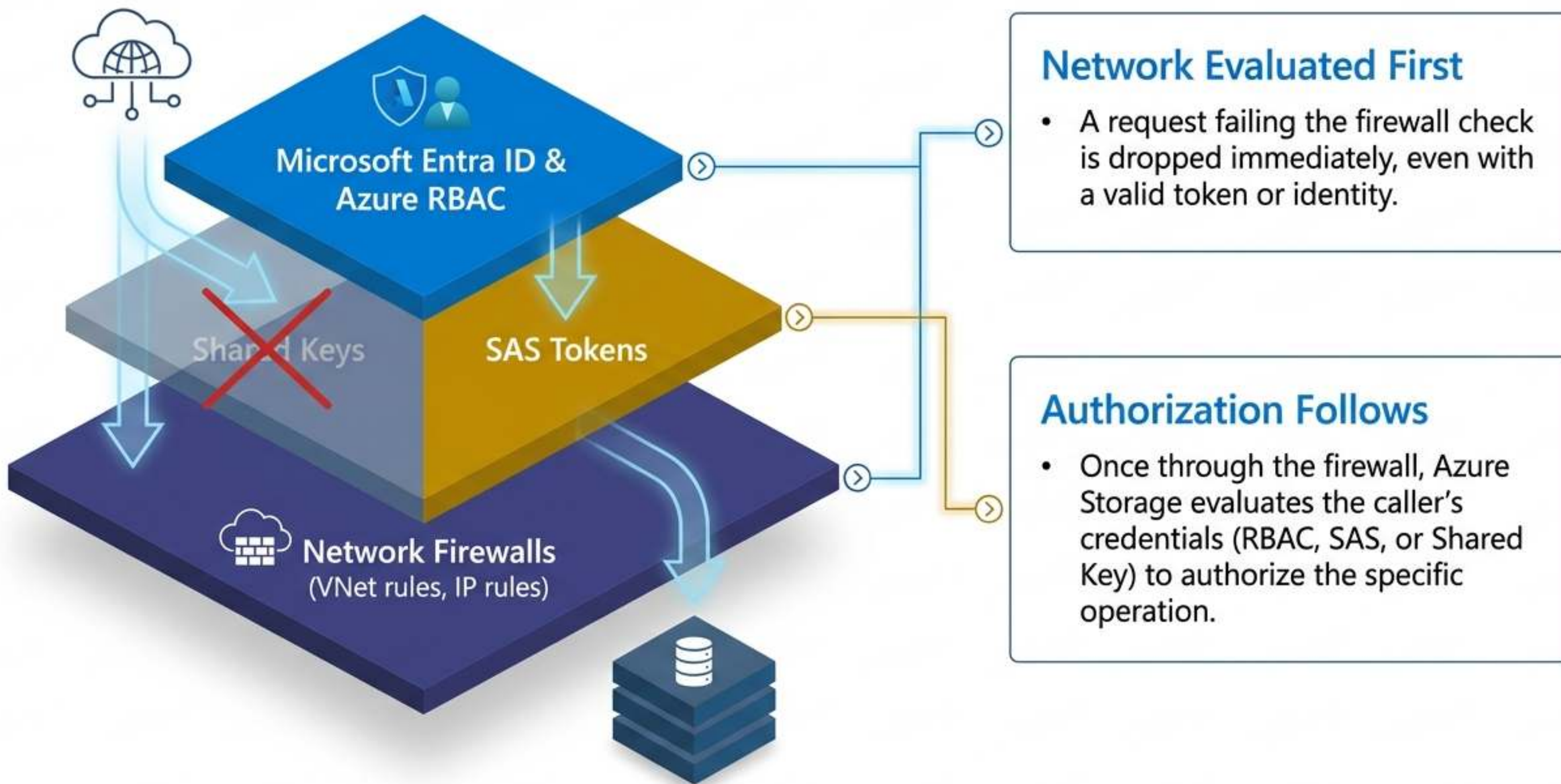
AZ-500 Exam Prep: SAS Tokens vs. Storage RBAC

Mastering Data Plane Access Mechanisms for Azure Storage

PROJECT:		
DOCUMENT NO:	DATE:	REVISION:

PROJECT:		
DOCUMENT NO:	DATE:	REVISION:

The Overlapping Defense Stack



Mapping the Boundaries: Control vs. Data Plane

Control Plane (The House)



Resource
Manager



Subscriptions



Account
Settings



Firewall
rules

Secured by standard
Azure RBAC
(e.g., Contributor, Owner)

Data Plane (The Furniture)



Blobs



Files



Queues

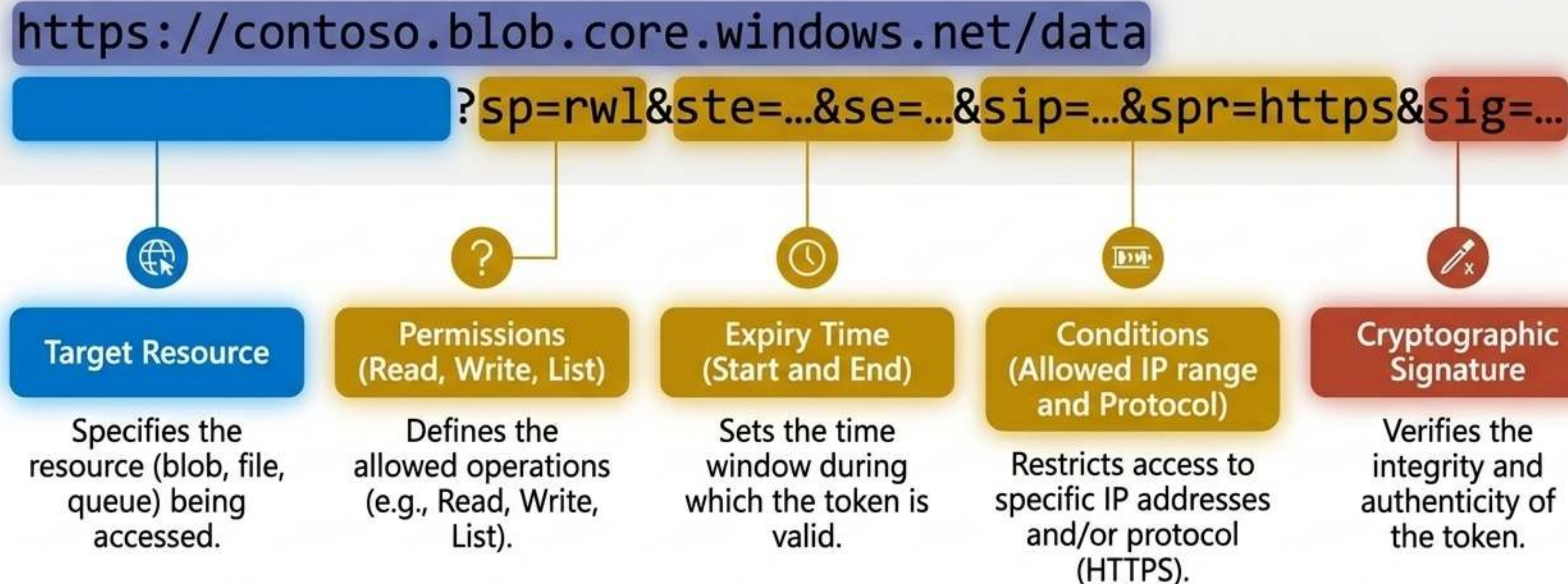


Tables

Secured by Data-Plane
Roles, SAS, or Shared Keys

Key Insight: Standard Azure RBAC (like Contributor) manages the account infrastructure but does not grant access to read or write the actual data. Data access requires specific Data-Plane roles or tokens.

Shared Access Signatures (SAS) Deconstructed



The Bearer Token Risk: A SAS token does not check who is using it. Whoever holds the URI holds the access until the exact second it expires.

The Three Flavors of SAS

Account SAS



Broadest scope.
Spans multiple services
(Blob, File, Queue).
Signed by the
overarching Account Key.

Service SAS



Scoped to a single
service (e.g., just Blobs).
Signed by the
Account Key.

User Delegation SAS



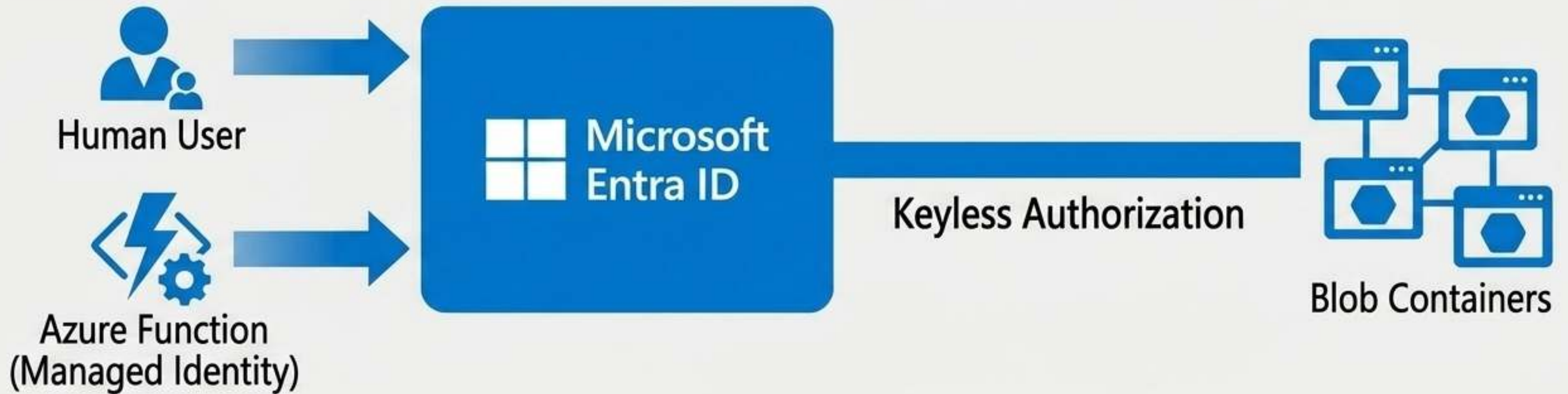
Signed with Entra ID
credentials using a
temporary delegation key,
completely bypassing
the Account Key.

The Revocation Dilemma & Blast Radius



Technical Note: Stored Access Policies only work with Service SAS. Account and User Delegation SAS cannot use them.

Storage RBAC: The Identity-Centric Standard



Zero Stored Secrets

Access is tied to a specific Entra ID identity (User, Group, or Managed Identity).
No connection strings or URIs to leak.

Critical Data-Plane Roles

- Storage Blob Data Reader (Read-only)
- Storage Blob Data Contributor (Read/Write/Delete)
- Storage Blob Data Owner (Full control + ACL management)

The Audit Trail Advantage

RBAC Visibility

Time: 2023-10-27T14:30:00Z
Action:
Caller:
Resource:
Time: 2023-10-27T14:30:00Z
Action: BlobRead
Caller: function-app-managed-id
Resource:
Caller: /subscriptions/.../
Resource: /storageAccounts/mystorage/ containers/mycontainer



SAS Blind Spot



SAS provides limited auditability; the token is verified, but the specific human or app holding it remains entirely anonymous.

Technical Note: RBAC provides granular identity-based logs, enabling detailed analysis. SAS logs only the token's usage, obscuring the true caller.

The Authorization Diagnostic Matrix

Mechanism	Requires Identity?	Revocable Instantly?	Fully Auditable?	Leak Blast Radius
Shared Key	No	No	No	Total Account Compromise
Service SAS (Ad hoc)	No	No	Partial	High
Service SAS (Stored Policy)	No	Yes (via Policy)	Partial	Contained
User Delegation SAS	Yes	Yes (via ID)	Better	Contained
Storage RBAC	Yes	Yes	Yes	Zero/Instant

Worked Scenario 1: The External Partner

The Requirement:

An external vendor needs temporary access (2 hours) to upload logs. They do not have an Entra ID account.

We must retain the ability to revoke access instantly if they are compromised.

Service SAS + Stored Access Policy



The Logic: Without an identity, RBAC and User Delegation SAS are out. A standard Ad hoc SAS cannot be revoked. A Service SAS tied to a Stored Access Policy provides the required stateless access while preserving the "kill switch".

Worked Scenario 2: The Internal App

The Requirement:

An internal Azure App Service needs persistent, programmatic access to read and write blobs. Access must be fully auditable and require zero manual credential rotation.

Storage RBAC + System-Assigned Managed Identity



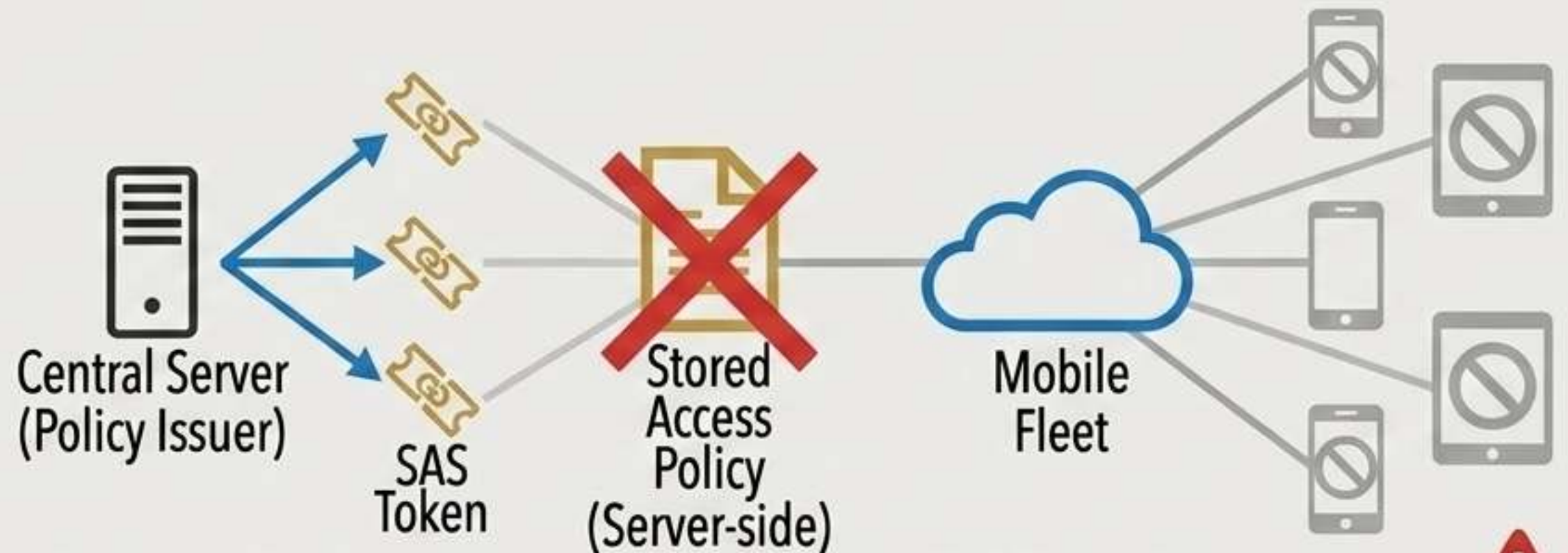
The Logic: The workload is inside Azure. Assigning it a Managed Identity and granting the Storage Blob Data Contributor role eliminates secrets entirely. Entra ID handles all auto-rotation and auditing.

Worked Scenario 3: Fleet Revocation

The Requirement:

You must issue thousands of individual upload tokens to mobile client devices. If a vulnerability is found in the mobile app, you must instantly revoke all issued tokens without rotating the main storage account keys.

! Service SAS tied to a Stored Access Policy



The Logic: You cannot rely on Ad hoc SAS (impossible to revoke without key rotation). By linking all mobile tokens to a single Stored Access Policy, deleting that server-side policy instantly invalidates every single token in the wild.

Beware the Tripwires: Top Exam Traps



Trap 1: The Revocation Myth

Assuming all SAS tokens can be revoked easily.

Reality: Ad hoc SAS tokens cannot be revoked without rotating the underlying account key.



Trap 2: The Identity Confusion

Forgetting how User Delegation SAS works.

Reality: It is signed by an Entra ID key, not the account key, making it the only Microsoft-recommended SAS.



Trap 3: The RBAC Illusion

Believing RBAC provides total lockdown by itself.

Reality: If Shared Key access is left enabled at the account level, an attacker with the key can bypass RBAC entirely.

The AZ-500 Survival Cheat Sheet

